

DG INTERNS HUB - CYBERSECURITY INTERNSHIP

WEEK 5 ASSIGNMENT

VAPT TOOLS - PRACTICAL LEARNING

VULNERABILITY ASSESSMENT & PENETRATION TESTING

Submitted By: Gunn Bhansali

Tools used: Nmap, Nikto, Burpsuite

Submission Date: 21 September 2026

INTRODUCTION

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify weaknesses, misconfigurations, and potential security issues in systems, networks, and web applications.

In this assignment, practical security testing was performed in an authorized lab environment using three commonly used cybersecurity tools: Nmap, Nikto, and Burp Suite.

Nmap was used for network scanning, port discovery, service/version detection, and basic host information gathering.

Nikto was used to perform web server scanning and identify common security-related issues and information disclosures.

Burp Suite was used to intercept and examine HTTP requests, headers, cookies, and other web traffic between the browser and the target application.

The objective of this practical was to understand the basic workflow of VAPT: reconnaissance, scanning, web assessment, traffic analysis, and documentation of findings.

TOOLS USED & OBJECTIVES

1. Nmap

Purpose: Network discovery and security scanning.

- **Host and port discovery**
- **Open/filtered port identification**
- **Service and version detection**
- **Basic OS detection**
- **Network reconnaissance**

2. Nikto

Purpose: Web server security assessment.

- **Web server scanning**
- **Server and technology identification**
- **Security header checks**
- **Information disclosure detection**
- **Common web server misconfiguration identification**

3. Burp Suite

Purpose: Web application traffic analysis.

- **Intercept HTTP requests**
- **Examine request and response headers**
- **Analyze cookies**

- **Understand browser-to-server communication**
- **Perform basic web security testing**

The main objectives of this practical were:

- 1. To understand the basic VAPT methodology.**
- 2. To gain hands-on experience with Nmap, Nikto, and Burp Suite.**
- 3. To identify security-related observations in an authorized testing environment.**
- 4. To analyze HTTP traffic and web server information.**
- 5. To document the testing process and findings with screenshots.**

NMAP PRACTICAL

1. NMAP – NETWORK SCANNING

Nmap (Network Mapper) is an open-source network scanning and reconnaissance tool used to discover hosts, identify open or filtered ports, detect services and their versions, and gather basic information about a target system.

Objective:

The objective of using Nmap was to perform basic network reconnaissance and understand the ports, services, and network information associated with the authorized target.

Nmap Commands Used:

1. SYN Scan- [nmap -sS testphp.vulnweb.com]

2. Service and Version Detection- [nmap -sV testphp.vulnweb.com]

3. Aggressive Scan nmap – [A testphp.vulnweb.com]

Figure 1: Nmap version verification

```
(kali㉿kali)-[~]  
$ nmap --version  
Nmap version 7.98 ( https://nmap.org )  
Platform: x86_64-pc-linux-gnu  
Compiled with: liblua-5.4.8 openssl-3.5.5 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.6 nmap-libdnet-1.18.0 ipv6  
Compiled without:  
Available nsock engines: epoll poll select  
  
(kali㉿kali)-[~]  
$
```

NMAP SCAN RESULTS & ANALYSIS

The following Nmap scans were performed against the authorized target to observe network availability, port responses, service information, and basic host characteristics.

Figure 2: DNS resolution of the target domain

A terminal window on a Kali Linux system. The prompt is (kali㉿kali)-[~]. The user enters the command nslookup testphp.vulnweb.com. The output shows the server 192.168.229.2 and address 192.168.229.2#53. Then, it shows a non-authoritative answer for the same domain with address 44.228.249.3. The background has a faint Kali Linux logo.

```
(kali㉿kali)-[~]  
$ nslookup testphp.vulnweb.com  
Server:      192.168.229.2  
Address:     192.168.229.2#53  
  
Non-authoritative answer:  
Name:   testphp.vulnweb.com  
Address: 44.228.249.3
```

Figure 3: Nmap SYN scan (-sS)

```
(kali㉿kali)-[~]  
$ nmap -sS testphp.vulnweb.com  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-18 12:53 +0530  
Nmap scan report for testphp.vulnweb.com (44.228.249.3)  
Host is up (0.00094s latency).  
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com  
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 1 IP address (1 host up) scanned in 5.04 seconds
```

```
(kali㉿kali)-[~]  
$
```

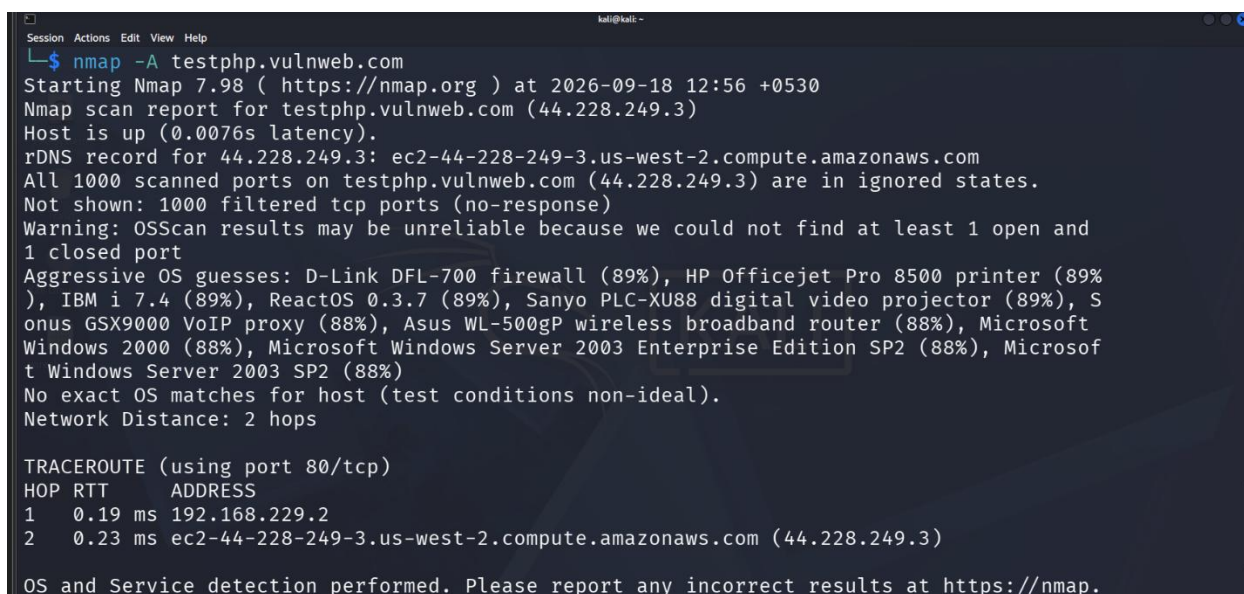
Figure 4: Nmap service and version detection (-sV)

```
(kali㉿kali)-[~]  
$ nmap -sV testphp.vulnweb.com  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-18 12:55 +0530  
Nmap scan report for testphp.vulnweb.com (44.228.249.3)  
Host is up (0.00068s latency).  
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com  
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 5.13 seconds  
  
(kali㉿kali)-[~]  
$  
  
(kali㉿kali)-[~]  
$
```

NMAP AGGRESSIVE SCAN & OBSERVATIONS

An aggressive scan was performed using the -A option. This option enables several advanced detection techniques, including service detection, OS detection, script scanning, and traceroute.

Figure 5: Nmap aggressive scan (-A)



```
kali@kali: ~  
$ nmap -A testphp.vulnweb.com  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-18 12:56 +0530  
Nmap scan report for testphp.vulnweb.com (44.228.249.3)  
Host is up (0.0076s latency).  
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com  
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Aggressive OS guesses: D-Link DFL-700 firewall (89%), HP Officejet Pro 8500 printer (89%), IBM i 7.4 (89%), ReactOS 0.3.7 (89%), Sanyo PLC-XU88 digital video projector (89%), Sonus GSX9000 VoIP proxy (88%), Asus WL-500gP wireless broadband router (88%), Microsoft Windows 2000 (88%), Microsoft Windows Server 2003 Enterprise Edition SP2 (88%), Microsoft Windows Server 2003 SP2 (88%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 2 hops  
  
TRACEROUTE (using port 80/tcp)  
HOP RTT ADDRESS  
1 0.19 ms 192.168.229.2  
2 0.23 ms ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org.
```

Nmap was successfully used to perform basic reconnaissance, SYN scanning, service/version detection, and aggressive scanning. The results provided information about the target's network response and filtering behavior.

2. NIKTO – WEB SERVER SCANNING

Nikto is an open-source web server scanner used to identify potentially insecure configurations, outdated server information, information disclosures, and missing security-related configurations.

Objective:

The objective of using Nikto was to perform a basic security assessment of an authorized web server and identify security-related observations that may require further investigation.

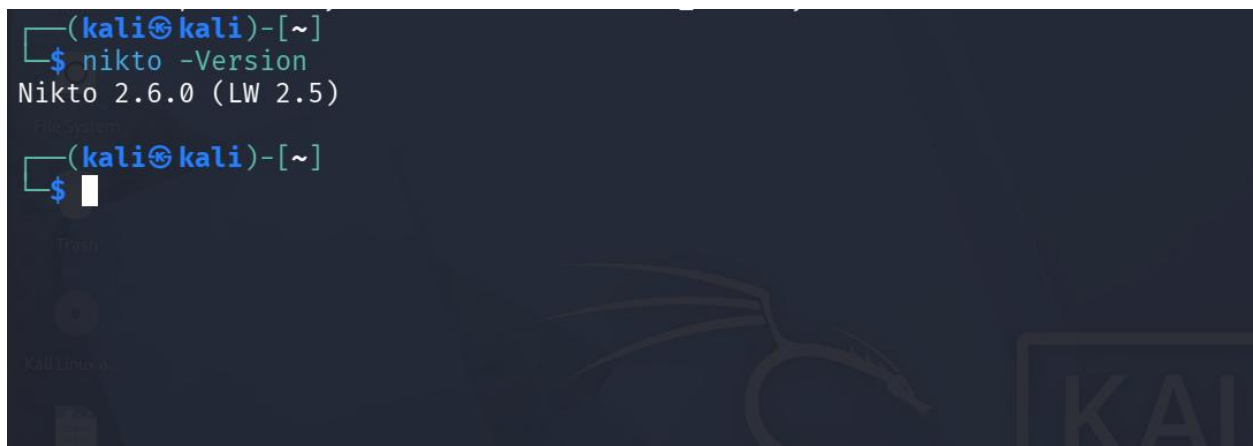
Target Used:

<http://testaspnet.vulnweb.com>

Command Used:

nikto -h <http://testaspnet.vulnweb.com>

Figure 6: Nikto version verification

A terminal window on a Kali Linux system. The prompt is (kali@kali)-[~]. The user enters the command \$ nikto -Version. The output is Nikto 2.6.0 (LW 2.5). The terminal has a dark background with a faint Kali Linux logo and the word KALI in the bottom right corner.

```
(kali@kali)-[~]  
$ nikto -Version  
Nikto 2.6.0 (LW 2.5)  
  
(kali@kali)-[~]  
$
```

NIKTO SCAN RESULTS & FINDINGS

A Nikto web server scan was performed against the authorized test web application. The scan identified several security-related observations involving server information disclosure and HTTP security configuration.

Figure 7: Nikto web server scan results

```
Session Actions Edit View Help
~$ nikto -h http://testaspnet.vulnweb.com -o report.txt
- Nikto v2.6.0

+ Target IP: 44.238.29.244
+ Target Hostname: testaspnet.vulnweb.com
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-09-18 18:12:17 (GMT5.5)

+ Server: Microsoft-IIS/8.5
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-aspnet-version header: 2.0.50727.
+ [999986] /: Retrieved x-powered-by header: ASP.NET.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999979] /aspnet_client: RFC-1918 IP address found in the 'location' header. The IP is "10.0.0.14". See: https://ports.wigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [999988] /aspnet_client: The web server may reveal its internal or real IP in the Location header via a request to wit h HTTP/1.0. The value is "10.0.0.14". See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HT TP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/W eb/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/doc s/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTT P/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/ Web/HTTP/CSP
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ [999985] OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ ERROR: *** Error limit (20) reached for host, giving up. Last error: opening stream: getaddrinfo problems (Temporary f ailure in name resolution): Resource temporarily unavailable. ***
+ ERROR: *** Consider using mitmproxy to avoid TLS fingerprinting. ***
- STATUS: Completed 1511 requests (~21% complete, ~1.7 hours left): currently in plugin 'Nikto Tests'
- STATUS: Running average: Not enough data.
+ Scan terminated: 10 errors and 11 items reported on the remote host
+ End Time: 2026-09-18 18:39:44 (GMT5.5) (1647 seconds)
```

Key Observations

- **Server Information Disclosure**
- **Internal IP Address Disclosure**
- **Missing Security Headers**

3. BURP SUITE – WEB TRAFFIC ANALYSIS

Burp Suite is a web application security testing platform that allows security professionals to intercept, inspect, and analyze HTTP/HTTPS traffic between a web browser and a web server.

Objective

The objective of using Burp Suite was to understand HTTP communication by capturing and analyzing requests sent from the browser to the authorized target application.

Proxy Configuration

Burp Suite's proxy listener was configured on the local system using the following settings:

Proxy Address: 127.0.0.1

Proxy Port: 8080

Practical Steps:

- 1. Started Burp Suite with a temporary project.**
- 2. Verified that the proxy listener was active on 127.0.0.1:8080.**
- 3. Configured the browser to use the Burp proxy.**
- 4. Opened the authorized target web application.**
- 5. Intercepted HTTP requests generated by the browser.**
- 6. Examined request methods, headers, and other HTTP information.**

Figure 8: Burp Suite proxy configuration and intercepted request

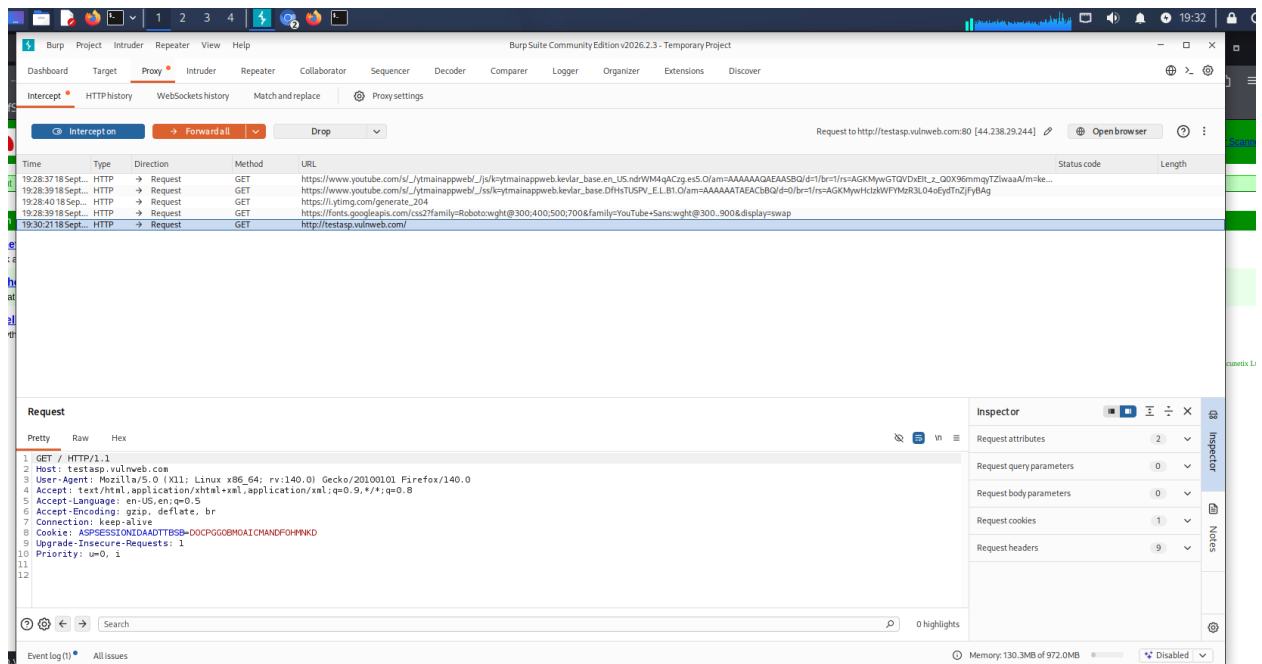
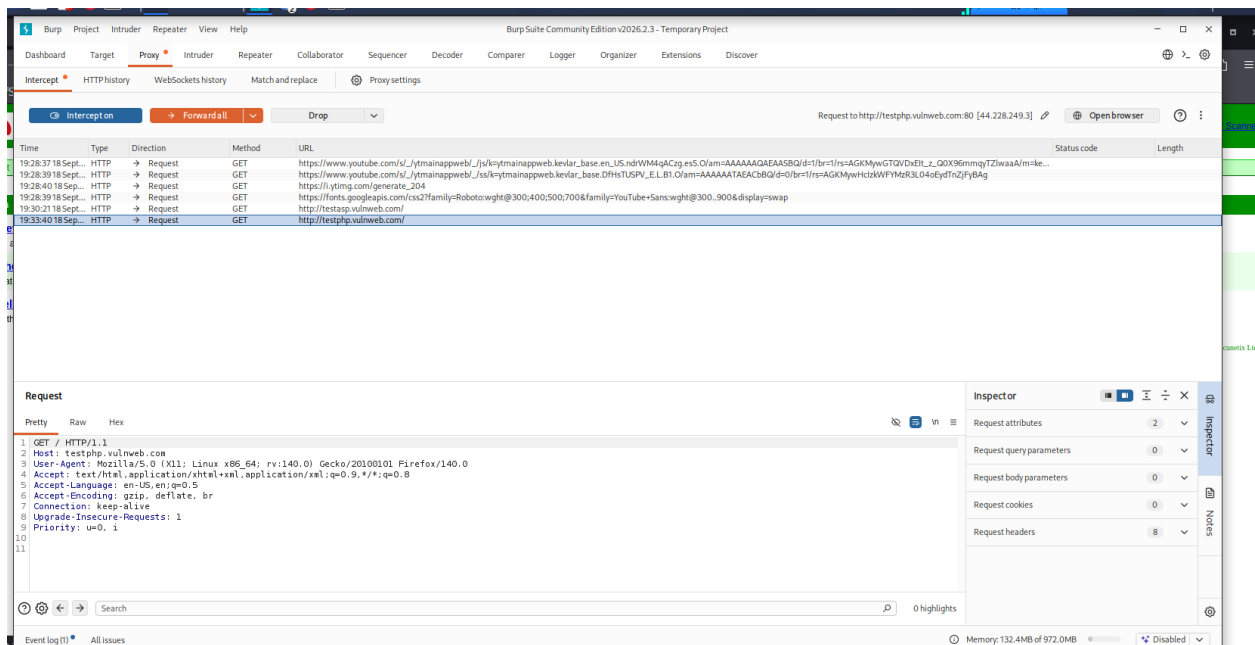


Figure 9: HTTP request captured using Burp Suite



BURP SUITE ANALYSIS & MINI TASK:

Burp Suite was used to intercept HTTP traffic generated while accessing the authorized test application. The captured requests provided practical information about HTTP methods, headers, host information, and browser-to-server communication.

Figure 10: HTTP request captured and analyzed using Burp Suite

The screenshot displays the Burp Suite Community Edition v2026.2.3 interface. The top menu bar includes options like Burp, Project, Intruder, Repeater, View, and Help. Below the menu, there's a toolbar with buttons for Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. The 'Proxy' tab is active, showing a list of intercepted HTTP requests. The list includes columns for Time, Type, Direction, Method, URL, Status code, and Length. The selected request is a GET request to http://testphp.vulnweb.com/.

Time	Type	Direction	Method	URL	Status code	Length
19:28:37 18 Sept...	HTTP	→ Request	GET	https://www.youtube.com/s/_ytmainappweb/_js/kymainappweb.kevlar_base.en_US.ndWM4gKcZg.es5.O/am=AAAAAGAEASBQ/d=1/b=1/rs=AGKM4yGTOVdxEIL_z_OOX96mmq/TZlwaaA/m=ke...		
19:28:39 18 Sept...	HTTP	→ Request	GET	https://www.youtube.com/s/_ytmainappweb/_js/kymainappweb.kevlar_base.DHtTUSPV_E.L.B1.O/am=AAAAAATAECBQ/d=0/b=1/rs=AGKM4yGTOVdxEIL_z_OOX96mmq/TZlwaaA/m=ke...		
19:35:25 18 Sept...	HTTP	→ Request	GET	https://www.youtube.com/manifest.webmanifest		
19:36:31 18 Sept...	HTTP	→ Request	GET	http://testphp.vulnweb.com/		
19:37:46 18 Sept...	HTTP	→ Request	GET	http://testphp.vulnweb.com/		

The detailed view of the selected request shows the following information:

- Request:** GET / HTTP/1.1
- Host:** testphp.vulnweb.com
- User-Agent:** Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
- Accept:** text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
- Accept-Language:** en-US,en;q=0.5
- Accept-Encoding:** gzip, deflate, br
- Connection:** keep-alive
- Upgrade-Insecure-Requests:** 1
- Priority:** u=0, i

The Inspector panel on the right shows the following details:

- Request attributes:** 2
- Request query parameters:** 0
- Request body parameters:** 0
- Request cookies:** 0
- Request headers:** 8

Mini Task – Security Findings

Finding 1 – Internal IP Address Disclosure

Nikto identified an internal IP address (10.0.0.14) in the web server response. This is an information disclosure that may reveal details about the internal network environment.

Finding 2 – Missing Security Headers

Nikto reported multiple missing recommended security headers, including Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy, and Permissions-Policy. These are security-hardening observations that should be reviewed by the web application administrator.

Finding 3 – Server/Technology Information Disclosure

The scan revealed server and technology information such as Microsoft-IIS/8.5 and ASP.NET. Exposing detailed technology information can assist reconnaissance and should be minimized where practical.

Burp Suite Observation

Burp Suite successfully demonstrated the interception and inspection of HTTP requests. The captured traffic helped in understanding request structure, headers, and communication between the browser and the target application.

OVERALL RESULTS & CONCLUSION

Overall Results

The VAPT practical was successfully performed using Nmap, Nikto, and Burp Suite in an authorized testing environment.

Nmap was used for network reconnaissance, SYN scanning, service/version detection, and aggressive scanning. The scans provided information about host availability and port filtering behavior.

Nikto identified several security-related observations, including server information disclosure, internal IP address disclosure, and missing recommended security headers.

Burp Suite was used to intercept and analyze HTTP requests, providing practical understanding of web traffic, HTTP methods, headers, and browser-server communication.

Conclusion

This practical provided hands-on experience with the basic VAPT workflow, from reconnaissance and scanning to web server assessment and HTTP traffic analysis. The exercise also demonstrated the importance of reviewing security configurations and minimizing unnecessary information exposure.

Overall, the practical improved understanding of commonly used VAPT tools and their role in identifying and documenting security-related observations in an authorized environment.

Key Learning Outcomes

- **Basic network reconnaissance using Nmap**
- **Web server scanning using Nikto**
- **HTTP traffic interception using Burp Suite**
- **Understanding ports, services, headers, and requests**
- **Identifying and documenting security-related findings**
- **Following an authorized and controlled security-testing methodology**